



AI Playbook and Toolkit for Public Health Departments

Identity, Access, and Permissions for AI Workflows

GOV 350

Identity, access, and permissions determine who or what can use data, systems, tools, and actions in an AI-supported workflow. Public health AI workflows may involve staff users, service accounts, APIs, vendors, plugins, agents, dashboards, and systems of record. Without clear access controls, an AI tool may retrieve sensitive data, expose information to unauthorized users, or take actions beyond the approved workflow. This module teaches technical, governance, and operational staff how to think about access control for AI. It goes beyond general cybersecurity by focusing on how permissions should be designed for AI-supported tasks, especially when tools retrieve data, summarize records, generate outputs, or write back to systems. Access design should follow least privilege, role-based permissions, auditability, and separation of duties. The goal is to give users and AI services enough access to perform approved tasks while preventing unnecessary exposure, unauthorized action, and hidden data flows.

Level	intermediate/practitioner
Primary track	Governance and Security Track
Appears in tracks	technical-architecture, governance-and-security, operations-and-data-quality

Learning Objectives

- Explain the difference between user identity, service identity, authentication, authorization, and permissions.
- Apply least-privilege principles to AI-supported public health workflows.
- Identify access risks for read-only, retrieval, summarization, and write-back AI functions.
- Define audit log and approval requirements for AI tools that access sensitive systems or data.
- Create an access and permissions review for an AI workflow.

Module Overview

Identity, access, and permissions determine who or what can use data, systems, tools, and actions in an AI-supported workflow. Public health AI workflows may involve staff users, service accounts, APIs, vendors, plugins, agents, dashboards, and systems of record. Without clear access controls, an AI tool may retrieve sensitive data, expose information to unauthorized users, or take actions beyond the approved workflow.

This module teaches technical, governance, and operational staff how to think about access control for AI. It goes beyond general cybersecurity by focusing on how permissions should be designed for AI-supported tasks, especially when tools retrieve data, summarize records, generate outputs, or write back to systems.

Access design should follow least privilege, role-based permissions, auditability, and separation of duties. The goal is to give users and AI services enough access to perform approved tasks while preventing unnecessary exposure, unauthorized action, and hidden data flows.

Jurisdiction and Agency Policy Note

This module provides national-level training guidance for public health agencies and partners. It is not legal advice and does not replace review by agency legal counsel, privacy officers, procurement officials, civil rights staff, records officers, or other authorized decision-makers. Requirements may vary by state, locality, territory, Tribe, agency, funding source, data-sharing agreement, emergency authority, and organizational policy. Learners should use this module to identify the issues that require review and should confirm applicable requirements before approving, procuring, deploying, or publicly communicating about AI-supported work.

Public Health Example

An AI assistant is approved to summarize case records for authorized disease investigators. The access review determines that the assistant may retrieve only records assigned to the investigator's program, may not access unrelated program data, may not export records to unapproved systems, and may not write final case notes without human approval. Logs must show which user requested the summary, which record was accessed, and whether the output was saved or discarded.

Technical and Operational Deep Dive

AI workflows may involve multiple identities. A staff member may log in through single sign-on, an AI service may use a service account to retrieve data, and a vendor system may process a request through an API. Each identity should be documented and tied to specific permissions. Agencies should avoid shared accounts or overly broad service accounts because they make accountability and incident investigation difficult.

Authentication verifies who or what is using the system, but authorization defines what that identity can do. For AI workflows, authorization should be granular enough to distinguish reading data, retrieving documents, generating summaries, creating tasks, sending notifications, and updating records. Write-back permissions should receive stronger review than read-only functions because they can change official records or trigger action.

Least privilege is especially important for AI because tools may process data at scale. A human user may look at one record at a time, but an AI integration may retrieve many records quickly. Permissions should limit data by role, program, jurisdiction, purpose, and workflow where possible. Sensitive data should not be accessible simply because it is technically available.

Audit logs should make AI access visible. Logs should capture user identity, service identity, data accessed, action taken, time, output generated, approval status, and errors or exceptions. For agentic workflows, logs should also show tool calls, attempted actions, blocked actions, and human approvals.

Risks, Failure Modes, and Guardrails

Risks and failure modes include the following:

Service accounts with broad access to sensitive data.

AI tools retrieving data unrelated to the approved use case.

Write-back actions occurring without human approval.

Shared accounts preventing accountability.

Insufficient logs to investigate data access or output generation.

Recommended guardrails include the following:

Use role-based and purpose-based access controls.

Apply least privilege to users, service accounts, APIs, and agents.

Require stronger approval for write-back, external transmission, and automated actions.

Avoid shared accounts and undocumented service identities.

Maintain detailed audit logs for AI access and actions.

Reflection Questions

Where does this topic appear in your agency, program, or workflow?

Which staff roles would need to understand or apply this concept before AI use is approved?

What could go wrong if this topic is not addressed before implementation?

What evidence would governance, leadership, or operations staff need before moving forward?

Which policy, data, equity, privacy, security, or workflow questions remain unresolved?

Practical Exercise

Create an identity, access, and permissions review for one AI-supported workflow. Identify users, service accounts, systems, data accessed, read/write permissions, approval points, prohibited actions, audit log requirements, and escalation triggers.

Expected Artifact or Evidence

Access and permissions review

List of user and service identities

Least-privilege recommendation

Write-back approval rules

Audit log requirements

Expected Assignment

- Access and permissions review
- List of user and service identities
- Least-privilege recommendation
- Write-back approval rules
- Audit log requirements

Knowledge Check

- 1. What is authorization?
- 2. Why are service accounts important in AI workflows?
- 3. What does least privilege mean?
- 4. Which AI function generally requires stronger safeguards?
- 5. What is strong completion evidence?

References and Resources

- NIST Artificial Intelligence Risk Management Framework: <https://www.nist.gov/itl/ai-risk-management-framework>
- NIST Generative AI Profile: <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>
- CDC Public Health Data Strategy and Data Modernization resources: <https://www.cdc.gov/public-health-data-strategy/php/about/index.html>
- OWASP guidance for LLM application security
- Agency policies for privacy, cybersecurity, records, procurement, accessibility, and public communications
- Relevant public health program SOPs, data governance documentation, and implementation plans